

Lean Technologies

Contract and Vendor Management Process

Approving Authority	CTO
Prepared By	IT Manager
Approval Date	Oct 2023
Next Scheduled Review	Oct 2024
Description	This document provides recommendations and guidelines to onboarding new vendors and contract management that are based upon Lean security policies and standards as well as industry standards.
Version	1.0

Contents

TABLE OF CONTENTS

Overview	3
1.1 Objective	3
1.2 Scope	3
1.3 Compliance	3
1.4 Exceptions	3
Contract and Vendor Management Policy	
2.1 Requirements	3
2.1.1 Due Diligence	3
2.2 Supplier Services	
2.2.1 Monitoring and Review	4
2.2.2 Changes to Supplier Services	4
2.2.3 Sub Contractor Services	5

1. Overview

1.1 Objective

To ensure that:

- Lean Tech's approved cyber security requirements are appropriately addressed before signing a contract; and
- Compliance with cyber security requirements is being monitored and evaluated during the contract life-cycle.

1.2 Scope

All supplier relations with Lean Tech involving information assets are within the scope of this policy. This includes suppliers involved in the storage, transmission and processing of information, even where the information is encrypted or otherwise generally inaccessible to the supplier.

1.3 Compliance

All new contracts must be designed to comply with the requirements prior to being introduced into a production environment. Existing contracts must develop a remediation plan to get into compliance with this standard as set by the cyber security requirements.

The below requirements are **minimum** standards. It is always acceptable to implement measures that are more stringent than what is documented below. Exceeding the minimum does not warrant a security exception.

1.4 Exceptions

Where compliance cannot be met or enforced due to unforeseen circumstances or vendor requirements, an exception must be filed, reviewed, and approved. The exception request must describe compensating security controls or risk acceptance. Exceptions must be submitted to the Lean Cyber Security Department.

2. Contract and Vendor Management Process

The following outlines the security requirements for each sub area regarding the vendor management lifecycle.

2.1 Requirements

Lean Technologies shall define, approve, implement, and communicate cyber security requirements within the contract and vendor management processes. These requirements shall be based on the Lean Tech's risk appetite and the sensitivity of the information assets that the vendor will have access to.

The controls in this section address the general security aspects of vendor management.

2.1.1 Due Diligence

- Lean Tech shall conduct a cyber security risk assessment of all potential vendors before signing a contract. This assessment shall include a review of the vendor's security posture, cyber security policies and procedures, and incident response plan.
- Lean Tech shall ensure that all contracts with vendors include specific cyber security requirements. These requirements shall be a baseline regardless of the vendor, and may also include requirements tailored to the specific risks associated with the vendor's services and the sensitivity of the information assets that the vendor will have access to.

- Engagement of new suppliers can only be undertaken with Cyber Security assessment as part of onboarding. This process ensures approval decisions and understand of supplier responses relating to the requirements take CS into account from the outset of the relationship
- Lean Tech shall define cyber security requirements for exiting, terminating, or renewing contracts with vendors. These requirements may include the return or destruction of all Lean Tech's data, the transfer of data to a new vendor, or the execution of a financial agreement.
- Lean Tech may choose to test the CS requirements based on an internal risk assessment. .
- Lean Tech shall provide a confidentiality agreement provided by the Legal Team regardless of vendor.

Following questions are required to be answered as part of the security Due Diligence process:

- What Lean data will the vendor platform have access to? Will the vendor store any Lean sensitive data?
- Is the vendor a SaaS solution or can it be self-hosted ? Where is the business/client data stored?
- Does the vendor have role based access control?
- Does the vendor have the option to configure SSO (e.g. via SAML)?
- Does the vendor have an audit mechanism?
- Does the vendor have MFA configurable?
- Does the vendor have any security certifications (e.g. ISO27001 or GDPR)?
- Did the vendor face any security incidents so far?
- Does the vendor have security SLAs in place for addressing security vulnerabilities?
- Was security testing performed on the vendor platform in the last 3m? Can it be shared?

Following questions are required to be answered as part of the Legal due diligence:

- What is the name of the vendor and what do they do?
- What services will the vendor be providing Lean?
- What is the expected duration of the contract?
- What is the anticipated cost of the vendor's products or services? is it fixed term one-off cost? subscription based?
- How critical is the vendor's work to Lean's business operations? Have you considered what business continuity steps we might need to put in place, should they be unable to provide the services to us?
- Are there any known risks associated with this vendor or their products/services? i.e. reputational / previous experience / new in the market etc.
- Has Lean conducted any due diligence on the vendor? If so, what were the results? i.e. have we checked whether we can integrate with them / technical capabilities
- Has Lean received a copy of the vendor's contract terms and conditions?
- What are Lean's expectations for vendor performance and deliverables? How will Lean monitor and measure the vendor's performance?
- What are our plans for terminating the relationship with the vendor? Do we require immediate termination rights or happy to rely on the term of the contract?
- Will the vendor have access to personal data? end-user data? client data? If so, do we know where that data will be processed, transferred and stored? What controls will we have over the data?

Following questions are required to be answered as part of the IT Due Diligence process:

- What is the number of user /paid licences you need?
- What are the modules within the tool that you need
- Is there any overlap between the new tool and an existing tool in terms of features/functionalities/use cases?

2.2 Supplier Services

2.2.1 Monitoring and Review

- The external party agreement includes reporting structures, defines acceptable levels of performance and provides monitoring inspection and audit rights where applicable.
- The account owner monitors the performance against the service and security criteria contained in the agreement, ensures that reports required under the agreement are delivered as required and reviews them, and conducts regular progress meetings as required.
- The account owner ensures that information security incidents experienced by the third party are reviewed jointly and that relevant information security incidents experienced internally are communicated to the third party so that appropriate steps can be taken.
- The account owner identifies any problems of any sort on either side of the relationship, and ensures that they are resolved, using the agreed escalation procedure where necessary.
- The account owner is responsible for reviewing the third party's internal audit trails and records of security events where applicable.
- Where a supplier has been selected on the basis of its compliance with an information security scheme or standard, the results of independent third-party audits will be deemed as evidence that information security controls are in place and operating effectively.
- On a regular basis, the CPO and CTO reviews all outstanding actions in respect of deficiencies in third-party services to ensure that appropriate corrective or preventative action is being taken, having regard to the fact that ultimate responsibility for the information processed by the third party remains with Lean Tech.

2.2.2 Changes to a Supplier Services

- Lean Tech may need to agree changes to external party contracts and agreements to take account of changes that it makes to, or as a result of:
 - o The services it currently offers to its clients;
 - o New applications and systems it has developed or acquired;
 - o Modifications, changes or updates to its own policies and procedures;
 - o New or amended controls arising from new risk assessments or information security incidents.
 - o The external party may need to request changes to the contract in order to implement:
 - o Changes or improvements to their networks or other infrastructure;
 - o New or improved technologies, new products or new releases of current products;
 - o New development tools, methodologies and environments;
 - o New physical locations or physical services;
 - o New vendors or other suppliers of hardware, software or services.
- Any changes that may be required are subject to a new risk assessment (considering the criticality of the business systems involved) and review of the selected controls.
- New controls, or changes to existing controls are identified, authorised, agreed with the third party, and made the subject of an agreed variation (via legal advisors) to the existing contract.
- The account owner is responsible for ensuring that the revised controls are implemented and incorporated into the existing review and monitoring arrangements.

2.2.3 Sub-Contractor Services

- Subcontractors are provided with a service contract which includes a confidentiality agreement covering the various responsibilities and actions required of the signatories in order to avoid unauthorised information disclosure, the permitted use of the information, the signatories' right in respect of that information and the required actions on termination of the agreement.